Power plants aren't firewalls The Iranian-linked breach knocked a UK generation hub offline for 96 hours, halting 1.2 GW of supply. How does a single OT intrusion reshape the skill set every analyst should chase?

** CAREER ADVICE** If you’re eyeing a jump from classic IT SOC to OT, start stacking the right certs now. **CISSP** gives you the governance backbone, but you’ll need **GICSP**, **CISA**, and the emerging **IEC 62443** specialist track to speak the language of engineers. Social engineering psychology is the secret sauce—most breaches still begin with a well-crafted phishing email, not a zero-day exploit. Practice credential-theft simulations on a sandbox HMI to internalize the human factor.

⚠ TECHNICAL INSIGHT What most teams assume: a hardened perimeter and a fancy SIEM are enough to stop nation-state actors. What actually happens: attackers exploit trust, reuse credentials, and slip through VPNs into SCADA networks, as the UK plant outage proved. The attack vector was a phishing lure that delivered a **C2** payload, then leveraged default admin on the PLC. In my last red-team exercise, I convinced a junior operator to click a link by pretending to be the vendor’s support line; within ten

Last week our team ran a tabletop on this scenario. I asked the shift lead to walk me through his password policy, and he admitted “same password everywhere.” That admission alone gave us a foothold without a single exploit.

** OPERATIONAL CHECKLIST** • Enforce unique, MFA-protected credentials for every HMI user. • Deploy network-segmentation with **Zero-Trust** micro-perimeters around PLC zones. • Run weekly phishing drills that mimic OT-specific lures. • Integrate **SOAR** playbooks that auto-isolate a PLC segment when anomalous command bursts appear. • Keep a dedicated OT analyst on call for real-time IOC triage.

In the next 12 months, any SOC without a dedicated OT analyst will be a liability, not an asset.

$ **POWER PLANTS AREN'T FIREWALL

 Tool Recommendation – **chrisneagu/FTC-Skystone-Dark-Angels-Romania-2020** (304) The open-source FTC SDK lets you prototype embedded control logic on a sandboxed robot platform. Repurposing the build environment to simulate PLC firmware gives junior analysts a safe playground to practice reverse-engineering and exploit mitigation without touching production gear. It’s a low-cost way to bridge the gap between code-level security and real-world OT operations

In 2025, 70% of power-grid SOCs will fail audits without an OT-focused analyst on duty. #OTSecurity #CyberCareer #CISSP #IEC62443 #PowerGrid | Source: https://www.securityweek.com/iran-linked-hackers-shut-down-uk